



BOSCH

México, Robert Bosch
Sistemas Automotrices,
S.A. de C.V

PROPUESTA DE UN SISTEMA GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (SGSI) BASADO EN EL ANEXO SL DE LAS NORMAS ISO/IEC

Responsables del documento

- Ávalos Rangel Hazel Mario – 181801
- Cabrera Meza Jorge Alejandro - 183095
- González Delgado Ángel Josué - 182837
- López Castro Diego – 182032
- López Monsiváis Jorge Emmanuel – 179842

Revisión

Mtro. Servando López Contreras

Fecha en la que se redacta

26 – Abril - 2026

CONFIDENTIAL



ÍNDICE

1.	Alcance	3
1.1.	Nombre de la empresa.....	3
1.2.	Dirección de la empresa	3
1.3.	Misión, visión y valores de la empresa.....	3
1.3.1.	Misión de Bosch.....	3
1.3.2.	Visión de Bosch	3
1.3.3.	Valores y principios de Bosch	4
1.4.	Área de alcance	4
1.5.	Propuesta de SGSI	4
1.5.1.	Activos considerados para el alcance	4
1.6.	Organigrama de la empresa	5
2.	Referencias normativas.....	5
3.	Términos y condiciones.....	6
4.	Contexto de la organización.....	7
5.	Liderazgo	9
1	información contenida en las bases de datos	9
2.	Gestor de bases de datos híbridas (DBMS).....	10
3.	Servidores físicos locales.....	10
4.	Sistemas de almacenamiento en la nube.....	10
5.	RespalDOS de información (Backups).....	11
6.	Dispositivos de almacenamiento físico (USBs, discos externos)	11
7.	Laptops del personal EDI	11
8.	Teléfonos móviles del personal full-time	12
9.	Plataformas y aplicaciones de control de versiones (OutSystems / Git)	12
10.	VPN Cisco (Seguridad de comunicaciones).....	13
6.	Planificación	20
7.	Soporte.....	24



7.1 Minuta de Concientización en Seguridad de la Información	24
MINUTA DE REUNIÓN	24
Objetivo de la reunión	24
Participantes	25
Temas tratados	25
1. Introducción al SGSI	25
2. Políticas de seguridad implementadas	25
3. Riesgos comunes identificados	25
4. Buenas prácticas	25
5. Responsabilidades del personal	26
Presentación informativa	26
8. Operación	27
8.1 Planificación y control operacional	27
Evaluación del Rendimiento	30
Checklist de Auditoría Interna del SGSI	30
Resumen de la Auditoría	35
Firma y Validación	35
9. Mejora	35
10.1 Descripción del Incidente: ¿Qué sucedió?	35
10.2 Análisis de Causa Raíz: ¿Por qué se materializó la amenaza?	36
10.3 Línea Temporal del Incidente (Cronología)	36
10.4 Conclusiones y Plan de Acción	37
Referencias bibliográficas	37

TABLA DE ILUSTRACIONES

Ilustración 1 Organigrama de BOSCH México	5
---	---



DEPARTAMENTO DE CIBSERSEGURIDAD DE LA UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ, MÉXICO	
Propósito del documento	Establecer una propuesta para un sistema gestión de seguridad de la información (SGSI) basado en el anexo SL de las normas ISO/IEC
Ficha en la que se emite el documento	26 de abril de 2026
Versión del documento	1.0

1. Alcance

1.1. Nombre de la empresa

Robert Bosch México Sistemas Automotrices, S.A. de C.V

1.2. Dirección de la empresa

La dirección de Bosch en San Luis Potosí es Eje Central 245, Zona Industrial, 78395 San Luis Potosí, S.L.P., México

1.3. Misión, visión y valores de la empresa

1.3.1. Misión de Bosch

La misión de Bosch se basa en ofrecer soluciones tecnológicas a los retos actuales de la humanidad, incluyendo la preservación del medio ambiente y los recursos naturales, con un enfoque en la innovación, la seguridad y la eficiencia. La empresa busca armonizar sus intereses con los de la sociedad y el planeta, promoviendo un equilibrio social y ecológico que asegure el éxito a largo plazo. Además, Bosch fomenta la participación y desarrollo de sus empleados, incentivando la formación continua y la transferencia de conocimientos a nivel global.

1.3.2. Visión de Bosch

La visión de Bosch se centra en la creación de valor y la sostenibilidad, guiada por principios como la credibilidad, la responsabilidad social y la innovación. La estrategia de sostenibilidad, denominada “New Dimensions”, define áreas clave de acción para mejorar la movilidad, la eficiencia energética y la protección del medio ambiente, con metas concretas a mediano y largo plazo. Bosch aspira a ser un socio confiable en la sociedad, promoviendo productos ecológicos y soluciones que benefician tanto a las generaciones presentes como futuras.



1.3.3. Valores y principios de Bosch

Bosch integra en su misión y visión valores fundamentales como:

- Orientación al cliente y calidad de los productos
- Innovación tecnológica y eficiencia
- Responsabilidad social y ambiental
- Credibilidad y ética profesional
- Desarrollo y valorización de los empleados

Estos principios reflejan el legado de Robert Bosch y constituyen el ADN de la empresa, asegurando que sus operaciones globales contribuyan a un mundo más sostenible y responsable.

1.4. Área de alcance

Electronic Data Interchange (EDI/4).

1.5. Propuesta de SGSI

El presente Sistema de Gestión de Seguridad de la Información (SGSI) tiene como alcance el departamento Easy.Go del área EDI número 4 de Robert Bosch, ubicado en San Luis Potosí, donde se desarrollan aplicaciones mediante la plataforma OutSystems. Su finalidad es establecer, implementar, mantener y mejorar continuamente un marco de protección de la información conforme a los lineamientos de la familia ISO 27000, particularmente ISO/IEC 27001 e ISO/IEC 27002, con el objetivo de salvaguardar la confidencialidad, integridad y disponibilidad de los activos de información involucrados en el ciclo de vida del desarrollo de software. Este SGSI contempla la identificación y tratamiento de riesgos asociados a vulnerabilidades como accesos no autorizados, exposición de datos sensibles, errores en configuraciones de la plataforma, fallos en la gestión de identidades y controles de acceso, dependencias de terceros, así como amenazas derivadas del desarrollo ágil y despliegues continuos. Asimismo, busca fortalecer los controles organizacionales, técnicos y operativos para asegurar el cumplimiento normativo, la protección de la propiedad intelectual y la resiliencia de los servicios digitales desarrollados.

1.5.1. Activos considerados para el alcance

Como se mencionó anteriormente, el fin último de la propuesta radica en salvaguardar la confidencialidad, integridad y disponibilidad de los activos de información involucrados en el ciclo de vida del desarrollo de software; por ello, los activos considerados para dicho propósito se presentan a continuación:

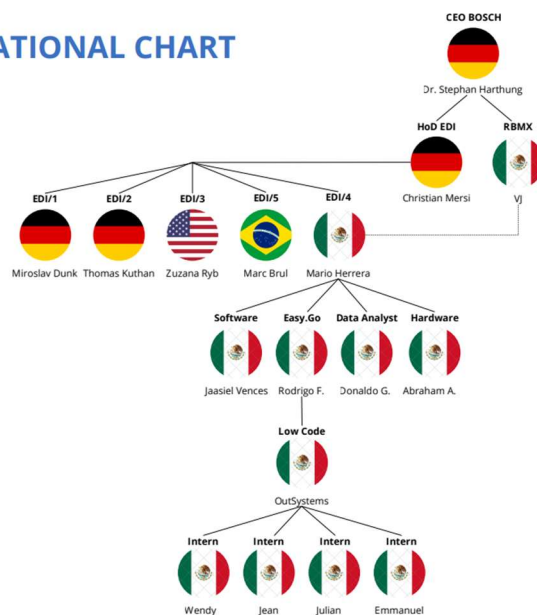
- Aplicaciones desarrolladas mediante la plataforma OutSystems.
- Plataforma de desarrollo de aplicaciones OutSystems.



- Bases de datos relacionales/no relacionales utilizadas para la gestión de información de las aplicaciones.
- Personal de desarrollo en el departamento.
- Equipos de cómputo.
- Dispositivos móviles del personal.
- Dispositivos de almacenamiento físicos.
- Sistemas de almacenamiento en la nube.
 - Plataformas y aplicaciones de control de versiones.
 - RespalDOS de información.
- Controles de acceso al departamento.
- Controles de acceso al software.

1.6. Organigrama de la empresa

ORGANITATIONAL CHART



¹ Nota del organigrama

Ilustración 1 Organigrama de BOSCH México

2.Referencias normativas

Para la correcta aplicación, implementación e interpretación de este SGSI se utiliza y hace referencia a la siguiente norma:

¹ *Organigrama propuesto con la información que ha sido facilitada por la empresa debido a fines de confidencialidad.*



ISO/IEC 27000: Sistemas de gestión de la seguridad de la información (visión general y vocabulario): Este estándar establece los principios, conceptos y definiciones fundamentales que sirven como base para la implementación y comprensión de los requisitos del SGSI descritos en el presente documento.

ISO/IEC 27001:2022: Requisitos de los Sistemas de Gestión de Seguridad de la Información Es la norma central que especifica los requisitos para establecer, implementar, mantener y mejorar continuamente el SGSI dentro del alcance definido. Proporciona el marco contra el cual se evaluará la conformidad del departamento a auditar el cual es Easy.Go.

ISO/IEC 27002:2022: Controles de Seguridad de la Información Funciona como una guía de referencia para la selección e implementación de los controles de seguridad. Es esencial para abordar las vulnerabilidades específicas mencionadas en el alcance, como el control de accesos y la gestión de identidades en el área EDI/4.

ISO/IEC 27034: Seguridad de las Aplicaciones Debido a que el departamento se especializa en el desarrollo mediante OutSystems, es de las normas más importantes ya que proporciona un marco para integrar la seguridad en todas las fases del ciclo de vida de desarrollo de software, asegurando que las aplicaciones sean seguras por diseño.

ISO/IEC 27005: Gestión de Riesgos de Seguridad de la Información Proporciona las directrices para el proceso de identificación, análisis y tratamiento de riesgos de seguridad, además de sustentar la metodología utilizada para evaluar las amenazas derivadas del desarrollo ágil y los despliegues continuos.

ISO/IEC 27031: Preparación de las TIC para la continuidad del negocio Esta norma apoya el objetivo de resiliencia de los servicios digitales mencionado en la propuesta, ofreciendo un marco para asegurar que la infraestructura tecnológica del departamento pueda responder ante incidentes graves.

3. Términos y condiciones

Para los propósitos de este documento y la correcta interpretación del SGSI en el departamento Easy.Go de Robert Bosch México, se aplican las siguientes definiciones basadas en la norma **ISO/IEC 27000**:



- **Activo de Información:** Se refiere a cualquier conocimiento o dato que tiene valor para el área de EDI/4, incluyendo código fuente en OutSystems, bases de datos de clientes, documentación técnica y credenciales de acceso.
- **Confidencialidad:** Propiedad de la información de no estar disponible ni ser revelada a individuos, entidades o procesos no autorizados durante el ciclo de vida del desarrollo de software.
- **Integridad:** Propiedad de salvaguardar la exactitud y completitud de las aplicaciones desarrolladas y los datos procesados en la plataforma.
- **Disponibilidad:** Propiedad de que la información y los servicios de las aplicaciones Easy.Go sean accesibles y utilizables cuando el departamento o el usuario final lo requieran.
- **Riesgo de Seguridad de la Información:** El efecto de la incertidumbre sobre los objetivos de seguridad de la información. Se mide en términos de la probabilidad de que una amenaza explote una vulnerabilidad.
- **Amenaza:** Causa potencial de un incidente no deseado que puede resultar en un daño a los sistemas de desarrollo o a los activos de la empresa.
- **Vulnerabilidad:** Debilidad de un activo o control que puede ser aprovechada por una o más amenazas (ej. una configuración incorrecta en el Service Center de OutSystems).
- **Gestión de Riesgos:** Actividades coordinadas para dirigir y controlar el departamento Easy.Go con respecto al riesgo de seguridad, incluyendo su identificación, análisis, evaluación y tratamiento.
- **Declaración de Aplicabilidad (SoA):** Documento que detalla los controles de la norma ISO/IEC 27001 seleccionados para el alcance de EDI/4, justificando su inclusión o exclusión.
- **Parte Interesada:** Persona u organización que puede afectar, verse afectada o percibirse como afectada por una decisión o actividad relacionada con el SGSI (ej. desarrolladores, gerencia de Bosch, clientes finales).
- **OutSystems (Low-Code):** Plataforma de desarrollo de aplicaciones de alta productividad que constituye el entorno tecnológico principal del alcance de este sistema.
- **Anexo SL:** Estructura de alto nivel utilizada por ISO para armonizar las normas de sistemas de gestión, facilitando la integración del SGSI con otros marcos de trabajo.Contexto de la Organiz

4.Contexto de la organización

Activos internos

1. Personal de departamento EDI



2. Laptops del personal EDI
3. Teléfonos móviles del personal full-time del departamento EDI
4. Gestor de base de datos híbridas
5. Información contenida en las bases de datos
6. Aplicaciones desarrolladas mediante la plataforma OutSystems
7. Plataforma de desarrollo de aplicaciones Outsystems
8. Dispositivos de almacenamiento físico
9. Sistemas de almacenamiento en la nube
10. Plataformas y aplicaciones de control de versiones
11. RespalDOS de información
12. Controles de acceso al departamento
13. Controles de acceso al software
14. Router Cisco
15. Sistema de videovigilancia
16. Switches cisco
17. Impresoras
18. VPN cisco
19. Firewall cisco
20. Servidores físicos locales cisco
21. Access Point (puntos de acceso wifi cisco)

Activos externos

1. Proveedores de servicios en la nube (SaaS, IaaS, PaaS de terceros)
2. Redes de Valor Añadido (VAN) para transacciones EDI
3. APIs y Webhooks de servicios externos
4. Consultores, contratistas y auditores externos
5. Redes de socios de negocio (Conexiones B2B / VPNs Site-to-Site)
6. Proveedores de Servicios de Seguridad Administrada (MSSP / SOC externo)
7. Proveedores de servicios de Internet (ISPs) y enlaces de telecomunicaciones
8. Servicios de DNS externos y registro de dominios
9. Herramientas de soporte y mantenimiento remoto de terceros
10. Bibliotecas de software y dependencias de terceros (Open Source)
11. Proveedores de almacenamiento físico externo (Custodia de respaldos off-site)
12. Proveedores de Identidad Externos (IdP / SSO en la nube)
13. Plataformas de entrega de contenido (CDNs) y mitigación DDoS externa
14. Plataformas de comunicación y colaboración en la nube
15. Sistemas de integración logística de terceros (3PL)
16. Repositorios de código fuente externos o públicos
17. Clientes o usuarios finales externos del portal EDI
18. Plataformas externas de capacitación o certificación



19. Fuentes de Inteligencia de Amenazas externas (Threat Intelligence Feeds)

20. Servicios externos de envíos de correo transaccional

5. Liderazgo

Activos internos seleccionados

- Personal de departamento EDI
- Información contenida en las bases de datos
- RespalDOS de información
- Sistemas de almacenamiento en la nube
- Dispositivos de almacenamiento físico
- Servidores físicos locales
- Laptops del personal EDI
- Teléfonos móviles del personal full-time
- Plataformas y aplicaciones de control de versiones
- VPN cisco
- Políticas activas internos

Política General de Protección, Acceso y Tránsito de la Información

Objetivo: Garantizar la confidencialidad, integridad y disponibilidad de la información corporativa en todos sus estados a través de la infraestructura del departamento EDI4 de la compañía Robert Bosch Sistemas Automotrices S.A de C.V.

1 información contenida en las bases de datos

- **Política:** Se debe garantizar la confidencialidad de la información crítica del negocio en todo momento y estado.
- **Estándar:** Toda la información clasificada como "Confidencial" debe estar cifrada tanto en reposo como en tránsito.
- **Directriz:** Se recomienda a los administradores utilizar herramientas automatizadas para el descubrimiento y etiquetado de nuevos datos sensibles.
- **Procedimiento:** Para clasificar un nuevo set de datos, el propietario debe:
1) Evaluar el nivel de impacto, 2) Asignar la etiqueta correspondiente en el sistema, 3) Aplicar el cifrado si es "Confidencial" o "Restringido".
- **Línea base:** El cifrado mínimo aceptable por defecto para datos en reposo es el algoritmo AES-256.



2. Gestor de bases de datos híbridas (DBMS)

- **Política:** El acceso lógico a las bases de datos debe estar estrictamente controlado, autenticado y auditado.
- **Estándar:** Todos los administradores y desarrolladores deben utilizar Autenticación Multifactor (MFA) para acceder al DBMS.
- **Directriz:** Los gerentes de área deben revisar y depurar los permisos de acceso de sus equipos de forma trimestral.
- **Procedimiento:** Para solicitar acceso al DBMS: 1) Llenar el formato de solicitud de accesos, 2) Obtener aprobación del gerente del departamento EDI, 3) TI crea el usuario asignando el rol correspondiente.
- **Línea base:** La configuración del DBMS por defecto debe tener deshabilitados los puertos de acceso público y habilitados los *logs* de auditoría transaccional.

3. Servidores físicos locales

- **Política:** Se debe proveer un entorno físico y lógico seguro para el procesamiento de la información corporativa.
- **Estándar:** Los servidores deben ubicarse en un centro de datos o cuarto de comunicaciones con control de acceso restringido.
- **Directriz:** Se recomienda mantener un monitoreo constante de temperatura y humedad en el cuarto de servidores mediante sensores automatizados.
- **Procedimiento:** Para que un ingeniero ingrese al *site* de servidores debe: 1) Registrar el motivo de la visita en la bitácora, 2) Escanear su gafete o huella biométrica, 3) Asegurarse de cerrar la puerta herméticamente al salir.
- **Línea base:** El sistema operativo de los servidores debe instalarse por defecto en su versión "Core" (sin interfaz gráfica) y con el firewall nativo encendido.

4. Sistemas de almacenamiento en la nube

- **Política:** La información almacenada en entornos de nube debe estar protegida contra exposición pública y accesos no autorizados.
- **Estándar:** Todos los *buckets* o contenedores de almacenamiento deben ser privados y no accesibles desde internet público.
- **Directriz:** Se aconseja al área de TI activar alertas de facturación para detectar anomalías o picos de transferencia que sugieran extracción de datos.
- **Procedimiento:** Para crear un nuevo contenedor en la nube: 1) Ejecutar la plantilla de Infraestructura como Código (IaC) autorizada, 2) Asignar el grupo de IAM, 3) Desplegar el recurso.



- **Línea base:** La política de identidad base debe tener la opción "Bloquear todo el acceso público" activada a nivel de cuenta.

5. RespalDOS de información (Backups)

- **Política:** Se debe asegurar la disponibilidad y rápida recuperación de la información ante cualquier incidente, falla o desastre.
- **Estándar:** Se debe cumplir estrictamente con la regla de respaldo 3-2-1 para toda la información crítica del negocio.
- **Directriz:** Se recomienda que el personal técnico rote en la ejecución de las pruebas de restauración para democratizar el conocimiento del plan de recuperación.
- **Procedimiento:** Para realizar una prueba de restauración semestral: 1) Seleccionar un backup aleatorio del servidor de producción, 2) Restaurarlo en un entorno aislado, 3) Validar la integridad de los datos, 4) Documentar el tiempo de recuperación.
- **Línea base:** La retención mínima por defecto para los respaldos diarios de bases de datos se establecerá en 30 días, con la inmutabilidad activada.

6. Dispositivos de almacenamiento físico (USBs, discos externos)

- **Política:** Se debe prevenir la fuga de información o la introducción de malware a través de medios extraíbles portátiles.
- **Estándar:** Queda estrictamente prohibido el uso de dispositivos USB personales; solo se permiten los provistos e inventariados por la empresa.
- **Directriz:** Se recomienda al personal evitar sacar los discos externos o USBs corporativas de las instalaciones de la empresa a menos que sea indispensable.
- **Procedimiento:** Para utilizar una USB corporativa: 1) Levantar un ticket justificando la necesidad, 2) TI entrega el dispositivo, 3) El usuario conecta la USB e ingresa la contraseña de descifrado cuando el sistema lo solicite.
- **Línea base:** La configuración mediante GPO en los equipos debe establecer los puertos USB en modo "Solo lectura" por defecto para dispositivos no registrados.

7. Laptops del personal EDI

- **Política:** Los equipos de cómputo portátiles deben mantenerse protegidos contra software malicioso, accesos no autorizados y robos.
- **Estándar:** Todas las laptops deben contar con el disco duro cifrado y la solución EDR (Endpoint Detection and Response) instalada.



- **Directriz:** Los usuarios de laptops deben atender anualmente a una sesión *online* de formación sobre la identificación de correos de *phishing*.
- **Procedimiento:** En caso de robo de la laptop, el usuario debe: 1) Notificar a TI en la primera hora del incidente, 2) TI ejecuta el bloqueo/borrado remoto, 3) El usuario levanta el acta correspondiente ante las autoridades.
- **Línea base:** La configuración de energía y seguridad por defecto debe bloquear la sesión del usuario tras 5 minutos de inactividad de teclado/mouse.

8. Teléfonos móviles del personal full-time

- **Política:** Los dispositivos móviles que procesen o accedan a datos del departamento EDI deben ser gestionados de manera segura.
- **Estándar:** Todo dispositivo móvil que reciba correo corporativo debe estar enrolado en la plataforma MDM (Mobile Device Management).
- **Directriz:** Se aconseja a los usuarios mantener apagadas las conexiones Bluetooth y Wi-Fi de sus equipos cuando no las estén utilizando.
- **Procedimiento:** Para configurar el acceso corporativo en el móvil: 1) Descargar la app del MDM, 2) Iniciar sesión con credenciales de la empresa, 3) Aceptar la creación del "Perfil de Trabajo" para aislar las apps laborales de las personales.
- **Línea base:** La política del MDM forzará un código de desbloqueo (PIN) mínimo de 6 dígitos numéricos o autenticación biométrica de forma predeterminada.

9. Plataformas y aplicaciones de control de versiones (OutSystems / Git)

- **Política:** El ciclo de desarrollo de software debe integrar controles de seguridad para proteger la integridad del código fuente corporativo.
- **Estándar:** Ningún desarrollador puede hacer *commits* directos a la rama principal de producción sin una revisión aprobatoria.
- **Directriz:** Se recomienda que los desarrolladores ejecuten escáneres de código estático en sus estaciones de trabajo antes de subir cualquier cambio.
- **Procedimiento:** Para integrar código nuevo: 1) Crear una rama de desarrollo, 2) Programar y hacer *commit*, 3) Crear un *Pull Request*, 4) Obtener la aprobación de un ingeniero par, 5) Fusionar el código (*Merge*).
- **Línea base:** Los repositorios de control de versiones deben estar configurados por defecto para rechazar la subida de archivos con extensiones críticas (como .pem, .key o .env).



10. VPN Cisco (Seguridad de comunicaciones)

- **Política:** Las comunicaciones remotas hacia la infraestructura interna de la organización deben realizarse exclusivamente a través de canales cifrados.
- **Estándar:** Todo acceso desde el exterior debe utilizar el cliente VPN de Cisco y requerirá de Autenticación Multifactor.
- **Directriz:** Se aconseja a los empleados desconectarse de la VPN al finalizar su jornada laboral para evitar saturación del ancho de banda institucional.
- **Procedimiento:** Para conectarse a la red interna: 1) Abrir el cliente Cisco AnyConnect, 2) Ingresar credenciales, 3) Aprobar el inicio de sesión desde la aplicación autenticadora en el teléfono móvil, 4) Esperar el mensaje de "Conectado".
- **Línea base:** El perfil de la VPN se configurará por defecto para bloquear el "túnel dividido", forzando todo el tráfico de internet de la laptop a pasar por el firewall corporativo.

Cláusula de Cumplimiento

Sanciones por Incumplimiento: El incumplimiento de estas políticas se considera una violación a las directrices de Seguridad de la Información (ISO 27001) y puede resultar en la revocación inmediata de accesos, sanciones disciplinarias, y en casos de negligencia grave, el despido justificado y acciones legales pertinentes.

Activos externos seleccionados

- Proveedores de servicios en la nube de terceros
- Redes de Valor Añadido (VAN) para transacciones EDI
- APIs y Webhooks de servicios externos
- Redes de socios de negocio (Conexiones B2B)
- Consultores, contratistas y auditores externos
- Proveedores de Servicios de Seguridad Administrada (MSSP)
- Herramientas de soporte y mantenimiento remoto de terceros
- Bibliotecas de software y dependencias de terceros
- Proveedores de almacenamiento físico externo
- Proveedores de Identidad Externos (IdP)

Política General de Gestión y Enlace con Activos Externos

Objetivo: Mitigar los riesgos asociados a la cadena de suministro y garantizar la seguridad, confidencialidad y disponibilidad de la información al interactuar con entidades, plataformas y servicios fuera del perímetro de la infraestructura del departamento EDI de la compañía.



1. Proveedores de servicios en la nube de terceros

- **Política:** El uso de servicios en la nube de terceros debe alinearse con los requisitos de seguridad corporativa para evitar la exposición de datos del departamento EDI.
- **Estándar:** Todo proveedor Cloud debe presentar un certificado SOC 2 Tipo II o ISO 27001 vigente antes de la firma del contrato.
- **Directriz:** Se sugiere priorizar proveedores que ofrezcan integración nativa con el directorio activo local para centralizar la gestión de identidades.
- **Procedimiento:** Para la contratación y despliegue: 1) Solicitar la evaluación de riesgos al área de cumplimiento, 2) Validar certificaciones del proveedor, 3) Firmar acuerdos de nivel de servicio (SLA) y confidencialidad, 4) Autorizar el inicio de operaciones.
- **Línea base:** La configuración inicial de cualquier tenant en la nube debe tener bloqueado el acceso público a los repositorios o buckets de almacenamiento por defecto.

2. Redes de Valor Añadido (VAN) para transacciones EDI

- **Política:** Las transacciones comerciales transmitidas a través de redes de terceros deben mantener su integridad y confidencialidad de extremo a extremo.
- **Estándar:** El intercambio de archivos EDI debe realizarse exclusivamente a través de protocolos cifrados con autenticación mutua, siendo AS2 o SFTP los autorizados.
- **Directriz:** Es recomendable programar ventanas de mantenimiento para la rotación de certificados digitales en horarios de bajo volumen transaccional para no interrumpir la logística.
- **Procedimiento:** Para dar de alta una nueva conexión VAN: 1) Generar el par de llaves criptográficas, 2) Intercambiar certificados públicos con el socio, 3) Configurar el puerto y credenciales en el gateway EDI, 4) Ejecutar pruebas de transmisión (loopback).
- **Línea base:** El cifrado en tránsito mínimo requerido para las conexiones VAN externas es TLS 1.2 o superior.

3. APIs y Webhooks de servicios externos

- **Política:** La interacción entre sistemas internos y APIs de terceros debe estar autenticada, controlada y protegida contra abuso de consumo o inyecciones.
- **Estándar:** Ninguna credencial, token o llave de API debe estar incrustada en texto plano dentro del código fuente de las aplicaciones.



- **Directriz:** Los desarrolladores deberían implementar mecanismos de reintentos con "exponential backoff" para manejar de manera eficiente las caídas temporales de los webhooks externos.
- **Procedimiento:** Para consumir un nuevo servicio externo: 1) Registrar la aplicación en el portal del proveedor, 2) Obtener el Client ID y Client Secret, 3) Almacenar las credenciales en la bóveda de secretos (Secret Vault), 4) Implementar la lógica de consumo.
- **Línea base:** El API Gateway interno debe tener configurado un límite de peticiones (rate limiting) predeterminado para evitar sobrecargas ante respuestas externas anómalas.

4. Redes de socios de negocio (Conexiones B2B)

- **Política:** Las conexiones de red directas con terceros deben aislarse estrictamente para prevenir movimientos laterales hacia la red interna corporativa.
- **Estándar:** Toda VPN Site-to-Site con un proveedor o cliente debe terminar en la zona desmilitarizada (DMZ) y estar regulada por reglas de firewall altamente restrictivas.
- **Directriz:** Se aconseja documentar y mantener actualizado un diagrama de flujo de red por cada conexión B2B activa para facilitar la resolución de problemas de enrutamiento.
- **Procedimiento:** Para habilitar un túnel B2B: 1) El socio llena el formulario de requerimientos técnicos de red, 2) Se negocian los parámetros criptográficos de las fases I y II de IPsec, 3) El área de redes configura el túnel, 4) Se aplican las listas de control de acceso (ACLs).
- **Línea base:** El túnel VPN debe utilizar obligatoriamente algoritmos de encriptación AES-256 y grupos Diffie-Hellman grupo 14 o superior.

5. Consultores, contratistas y auditores externos

- **Política:** El personal externo operará bajo el principio de menor privilegio, accediendo únicamente a los recursos de información necesarios para cumplir con sus obligaciones contractuales.
- **Estándar:** Las cuentas de usuario para personal externo deben tener una fecha de expiración configurada en el sistema desde el momento exacto de su creación.
- **Directriz:** Los líderes de proyecto deben auditar periódicamente las actividades de los consultores en los sistemas críticos durante la vigencia de su asignación.



- **Procedimiento:** Para el alta de externos: 1) Firmar el Acuerdo de Confidencialidad (NDA), 2) El área solicitante levanta el ticket indicando la fecha de término del contrato, 3) TI entrega credenciales temporales, 4) El Active Directory deshabilita la cuenta automáticamente al llegar la fecha.
- **Línea base:** Todas las cuentas de invitados o externos requieren la configuración y validación de Autenticación Multifactor (MFA) antes del primer inicio de sesión.

6. Proveedores de Servicios de Seguridad Administrada (MSSP)

- **Política:** La externalización del monitoreo de seguridad y gestión de eventos no debe comprometer la privacidad de los datos internos ni la soberanía de la información del departamento.
- **Estándar:** Los logs enviados al SOC externo deben ser filtrados previamente para enmascarar o anonimizar cualquier información personalmente identificable (PII) o datos financieros.
- **Directriz:** Se recomienda agendar sesiones de revisión mensuales con el proveedor del MSSP para afinar las reglas de detección de alertas y reducir los falsos positivos.
- **Procedimiento:** Para la integración de logs: 1) Definir el alcance de los servidores y dispositivos de red a monitorear, 2) Configurar el enmascaramiento y reenvío de logs (syslog/agentes), 3) Validar que el MSSP reciba los eventos estructurados, 4) Aprobar la matriz de escalamiento.
- **Línea base:** El canal de comunicación para la exportación de bitácoras hacia el MSSP debe estar cifrado de extremo a extremo mediante mTLS.

7. Herramientas de soporte y mantenimiento remoto de terceros

- **Política:** El soporte remoto por parte de fabricantes a la infraestructura crítica debe ser explícitamente autorizado, documentado, supervisado y registrado.
- **Estándar:** Las sesiones de soporte administrativo de terceros deben realizarse exclusivamente a través de la plataforma de Gestión de Acceso Privilegiado (PAM) corporativa.
- **Directriz:** Los administradores locales tienen la responsabilidad de informar a los usuarios si una sesión de soporte externa requerirá reiniciar servicios críticos durante el horario laboral.
- **Procedimiento:** Para autorizar una conexión externa: 1) El proveedor solicita una ventana de mantenimiento, 2) El comité aprueba el ticket de cambio, 3) Se genera un enlace de acceso web temporal en la solución PAM, 4) La sesión se ejecuta y se graba en video para auditoría.



- **Línea base:** La configuración del software PAM no debe permitir la transferencia de archivos bidireccional ni el uso del portapapeles entre el equipo externo y el servidor local por defecto.

8. Bibliotecas de software y dependencias de terceros

- **Política:** Todo código abierto o paquete de terceros integrado en los desarrollos del departamento debe estar libre de vulnerabilidades críticas conocidas.
- **Estándar:** Es obligatorio ejecutar herramientas de Análisis de Composición de Software (SCA) en el código fuente antes de autorizar cualquier paso a producción.
- **Directriz:** Los equipos de desarrollo deben evaluar la salud de los repositorios públicos de las dependencias antes de adoptarlas, asegurando que el proyecto externo se mantenga activo y reciba actualizaciones frecuentes.
- **Procedimiento:** Para gestionar vulnerabilidades en librerías: 1) Ejecutar la herramienta SCA en la tubería CI/CD, 2) Revisar el reporte automático de hallazgos, 3) Si se detectan CVEs, actualizar la versión de la dependencia a una segura, 4) Recompilar y pasar pruebas.
- **Línea base:** El umbral de aceptación del pipeline bloqueará automáticamente el paso a producción de cualquier aplicativo que contenga librerías con vulnerabilidades marcadas con un score CVSS v3 mayor a 7.0.

9. Proveedores de almacenamiento físico externo (Custodia off-site)

- **Política:** Los medios físicos de respaldo de la empresa almacenados fuera de las instalaciones deben protegerse contra pérdida, robo o acceso indebido durante su tránsito y resguardo.
- **Estándar:** Cualquier cinta magnética LTO o disco duro enviado a las bóvedas de custodia externa debe estar cifrado en su totalidad antes de salir del sitio.
- **Directriz:** Es buena práctica realizar una auditoría física anual, sin previo aviso, visitando las instalaciones del proveedor para verificar las condiciones ambientales y los controles de acceso del sitio.
- **Procedimiento:** Para la rotación de cintas: 1) Ejecutar el trabajo de respaldo cifrado en el servidor, 2) Embalar las cintas en maletines de transporte rígidos y sellados, 3) Llenar y firmar la bitácora de cadena de custodia con el personal del proveedor, 4) Archivar el recibo.
- **Línea base:** El algoritmo de cifrado mínimo configurado en la consola de backup para cintas destinadas a off-site es AES-256.



10. Proveedores de Identidad Externos (IdP)

- **Política:** La validación de identidades delegada a plataformas en la nube debe asegurar que solo usuarios verificados y dispositivos confiables accedan a las aplicaciones corporativas.
- **Estándar:** La integración de aplicaciones internas o de terceros con el proveedor de identidad debe utilizar únicamente protocolos modernos de federación, como SAML 2.0 u OpenID Connect (OIDC).
- **Directriz:** Se recomienda a los administradores de TI suscribirse a los boletines de seguridad del proveedor del IdP para monitorear posibles brechas o actualizaciones de seguridad globales.
- **Procedimiento:** Para federar una nueva aplicación: 1) Configurar el aplicativo como "Service Provider", 2) Establecer la confianza intercambiando metadatos y certificados con el IdP, 3) Mapear los atributos y grupos requeridos, 4) Ejecutar pruebas funcionales de Single Sign-On (SSO).
- **Línea base:** Las políticas de acceso condicional del IdP deben tener habilitado un bloqueo geográfico (Geo-blocking) por defecto para rechazar intentos de inicio de sesión desde países sancionados o donde la empresa no tiene operaciones.

Cláusula de Cumplimiento

- **Sanciones por Incumplimiento:** El uso no autorizado de servicios externos o plataformas de terceros para procesar código o datos corporativos (*Shadow IT*), así como la omisión de las políticas aquí descritas, constituye una violación grave. Esto resultará en la revocación de accesos, el inicio de investigaciones de seguridad y las consecuentes acciones disciplinarias o legales aplicables.

Matriz de RACI de políticas de seguridad

Política	Project Manager	Team Lead	Developer	Tester	Stakeholder
Políticas Internas					
Información contenida en las bases de datos	A	R	C	I	I
Gestor de bases de datos híbridas (DBMS)	I	A	I	I	I



Servidores físicos locales	A	R	C	I	I
Sistemas de almacenamiento en la nube	I	A	I	I	I
Respaldos de información (Backups)	A	R	I	I	I
Dispositivos de almacenamiento físico (USBs, discos externos)	I	A	R	R	I
Laptops del personal EDI	I	A	I	I	I
Teléfonos móviles del personal full-time	A	R	C	I	I
Plataformas y aplicaciones de control de versiones (OutSystems / Git)	I	A	I	I	I
VPN Cisco (Seguridad de comunicaciones)	A	R	C	I	I
Políticas externas					
Proveedores de servicios en la nube de terceros	A	C	I	I	R
Redes de Valor Añadido (VAN) para transacciones EDI	I	A	R	C	I
APIs y Webhooks de servicios externos	I	A	R	R	I
Redes de socios de negocio (Conexiones B2B)	A	C	R	I	C



Consultores, contratistas y auditores externos	R	I	I	I	A
Proveedores de Servicios de Seguridad Administrada (MSSP)	A	R	I	I	I
Herramientas de soporte y mantenimiento remoto de terceros	A	R	I	I	C
Bibliotecas de software y dependencias de terceros	I	A	R	C	I
Proveedores de almacenamiento físico externo (Custodia off-site)	A	C	I	I	R
Proveedores de Identidad Externos (IdP)	A	R	C	I	C

Leyenda

R	Responsable
A	Aprobador
C	Consultado
I	Informado

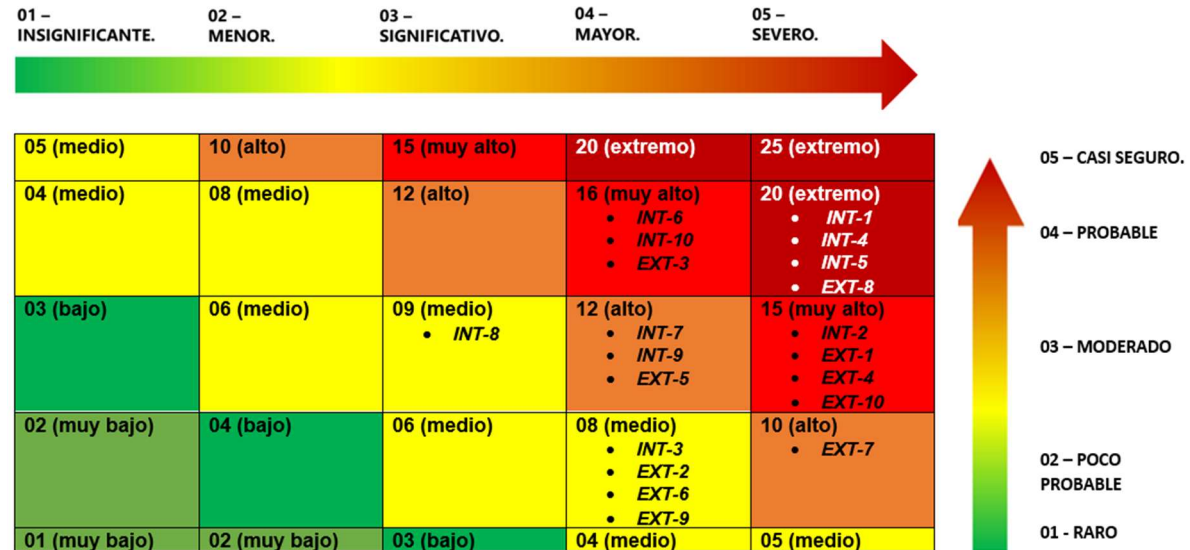
6. Planificación

En la siguiente matriz de riesgos, se han identificado los niveles de riesgo de cada una de las políticas basados en los 10 activos internos y 10 activos externos propuestas para este SGS.



Seguido de la matriz de riesgo, se anexa una tabla de detalles en la cual se hace una interpretación de esta matriz para una mejor comprensión.

Matriz de Riesgo



En la siguiente tabla, se detalla la anterior matriz de riesgo considerando los puntos viñetados como ID para poder identificar a cada uno.

Tabla de detalle

ID	Política	Riesgo a prevenir	Probabilidad	Impacto	Nivel de Riesgo	Acción de la Política
INT-1	Bases de datos	Fuga o robo de información confidencial en texto plano.	04 Probable	05 Severo	20 (Extremo)	Mitigar (Cifrado AES-256 y clasificación)
INT-2	Gestor de BD (DBMS)	Accesos no autorizados que comprometan la integridad de los datos.	03 Moderado	05 Severo	15 (Muy Alto)	Mitigar (MFA, auditoría y control de roles).
INT-3	Servidores físicos	Daño físico, robo o sabotaje directo a la	02 Poco Probable	04 Mayor	08 (Medio)	Mitigar (Control



		infraestructura central.				biométrico y sensores).
IN T-4	Almacenamiento en Nube	Exposición accidental de datos corporativos a internet público.	04 Probable	05 Severo	20 (Extremo)	Mitigar (Bloqueo público e laC).
IN T-5	Respallos (Backups)	Pérdida irrecuperable de datos por ransomware o desastres.	04 Probable	05 Severo	20 (Extremo)	Mitigar (Regla 3-2-1 e inmutabilidad).
IN T-6	Almacenamiento físico (USBs)	Infección por malware e infiltración/exfiltración de datos.	04 Probable	04 Mayor	16 (Muy Alto)	Mitigar (GPO de solo lectura, USBs cifradas).
IN T-7	Laptops personal del	Robo de equipo portátil resultando en fuga de datos e intrusión.	03 Moderado	04 Mayor	12 (Alto)	Mitigar (Cifrado de disco, EDR, bloqueo remoto).
IN T-8	Teléfonos móviles	Pérdida del dispositivo y acceso a correos/sistemas corporativos.	03 Moderado	03 Significativo	09 (Medio)	Mitigar (MDM, Perfil de trabajo, PIN biométrico).
IN T-9	Control de versiones (Git)	Inyección de código malicioso o exposición de llaves/secretos.	03 Moderado	04 Mayor	12 (Alto)	Mitigar (Pull requests, escáner de código).
IN T-10	VPN Cisco	Interceptación de tráfico remoto o acceso no autorizado a red.	04 Probable	04 Mayor	16 (Muy Alto)	Mitigar (Túnel cifrado sin división, MFA).



EX T-1	Proveedores Cloud	Brecha de seguridad derivada de infraestructura de terceros.	03 Moderado	05 Severo	15 (Muy Alto)	Transferir / Mitigar (Exigir SOC 2 / ISO 27001).
EX T-2	Redes VAN para EDI	Interceptación de datos logísticos/financieros en tránsito B2B.	02 Poco Probable	04 Mayor	08 (Medio)	Mitigar (Cifrado TLS 1.2+, AS2/SFTP).
EX T-3	APIs y Webhooks	Abuso de consumo, ataques de denegación de servicio (DDoS).	04 Probable	04 Mayor	16 (Muy Alto)	Mitigar (Rate limiting, bóveda de secretos).
EX T-4	Redes B2B	Movimiento lateral hacia la red interna desde un socio vulnerado.	03 Moderado	05 Severo	15 (Muy Alto)	Mitigar (Túneles en DMZ, ACLs, IPsec).
EX T-5	Consultores externos	Abuso de privilegios o persistencia no autorizada en sistemas.	03 Moderado	04 Mayor	12 (Alto)	Mitigar (Cuentas con expiración, mínimo privilegio).
EX T-6	Proveedores MSSP	Fuga de datos personales (PII) a través de bitácoras exportadas.	02 Poco Probable	04 Mayor	08 (Medio)	Mitigar (Enmascaramiento de logs, mTLS).
EX T-7	Soporte de terceros	Cambios críticos no autorizados o instalación de puertas traseras.	02 Poco Probable	05 Severo	10 (Alto)	Mitigar (PAM, sesiones grabadas, supervisión).
EX T-8	Dependencias/S software	Explotación de vulnerabilidades heredadas (ataques de	04 Probable	05 Severo	20 (Extremo)	Mitigar (Análisis SCA, bloqueo



		cadena de suministro).				por CVSS > 7.0).
EX T-9	Custodia Off-site	Robo o extravío de cintas magnéticas durante el traslado físico.	02 Poco Probable	04 Mayor	08 (Medio)	Mitigar (Cifrado LTO AES-256, cadena de custodia).
EX T-10	Proveedores IdP	Suplantación de identidad desde ubicaciones geográficas anómalas.	03 Moderado	05 Severo	15 (Muy Alto)	Mitigar (SAML/OIDC, Geo-blocking, MFA).

7. Soporte

7.1 Minuta de Concientización en Seguridad de la Información

MINUTA DE REUNIÓN

Empresa: Robert Bosch Sistemas Automotrices
Departamento: Easy.Go – EDI/4
Tema: Concientización sobre Seguridad de la Información y SGSI
Fecha: 15 de mayo de 2026
Hora: 10:00 AM – 10:46 AM
Lugar: Sala de juntas EDI/4 / Microsoft Teams
Responsable: Departamento de Ciberseguridad UPSLP
Moderadores: Diego López Castro, Hazel Mario Ávalos Rangel

Objetivo de la reunión

Concientizar al personal del departamento EDI/4 sobre la importancia del Sistema de Gestión de Seguridad de la Información (SGSI), así como reforzar buenas prácticas de seguridad para proteger la confidencialidad, integridad y disponibilidad de la información corporativa.



Participantes

- Project Manager
- Team Lead
- Developers
- Testers
- Personal de TI
- Contratistas autorizados

Temas tratados

1. Introducción al SGSI

- Definición de SGSI.
- Importancia de ISO/IEC 27001.
- Riesgos de seguridad en el desarrollo de software.

2. Políticas de seguridad implementadas

- Uso correcto de VPN Cisco.
- Manejo seguro de contraseñas.
- Uso de MFA.
- Protección de información confidencial.
- Control de acceso a repositorios y bases de datos.

3. Riesgos comunes identificados

- Phishing.
- Robo de credenciales.
- Uso de USB no autorizadas.
- Fuga de información.
- Vulnerabilidades en librerías externas.

4. Buenas prácticas

- Bloquear equipos al ausentarse.
- No compartir accesos.
- Reportar incidentes inmediatamente.
- Uso correcto del correo corporativo.



- Actualización constante de software.

5. Responsabilidades del personal

- Cumplir políticas del SGSI.
- Participar en capacitaciones.
- Reportar incidentes y anomalías.
- Proteger activos de información.

Acuerdos establecidos

Acuerdo	Responsable	Fecha compromiso
Capacitación anual de phishing	TI / Seguridad	Semestral
Revisión de accesos	Team Leads	Trimestral
Validación de MFA	TI	Inmediato
Simulacros de incidentes	Seguridad Informática	Próximo trimestre

Presentación informativa

PROYECTO SGSI EDI/4

Concientización en Seguridad de la Información

ISO/IEC 27001 | Robert Bosch Sistemas Automotrices

Responsables

Ávalos Rangel Hazel Mario – 181801
Cabrera Meza Jorge Alejandro - 183095
González Delgado Ángel Josué - 182837
López Castro Diego – 182032
López Monsiváis Jorge Emmanuel – 179842

CONFIDENTIAL

¿QUÉ ES UN SGSI?

Definición

Un Sistema de Gestión de Seguridad de la Información es un conjunto de políticas, procesos y controles diseñados para proteger la información de la organización de forma sistemática y segura.

Los 3 Pilares ISO 27001

Confidencialidad: Solo autorizados acceden.

Integridad: Información sin alteraciones.

Disponibilidad: Acceso cuando se requiere.

IMPORTANCIA DE LA SEGURIDAD

¿Por qué es vital hoy?

En el entorno EDI/4, la información es nuestro activo más valioso. Protegernos asegura:

- Continuidad operativa de la planta.
- Protección de propiedad intelectual.
- Cumplimiento legal y normativo.
- Confianza de clientes y socios.



CONFIDENTIAL

AMENAZAS MÁS COMUNES



Phishing

Correos falsos que
buscan robar
credenciales.



Malware

Software malicioso que
daña sistemas.



Social Eng.

Manipulación para
obtener acceso.

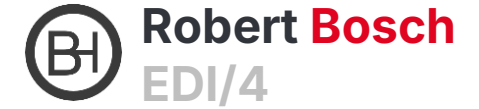


USB Inseguro

Fuga de datos por
medios extraíbles.

"El eslabón más débil suele ser el factor humano. La prevención es nuestra mejor arma."

POLÍTICAS EDI/4



- ✓ **MFA:** Autenticación Multifactor obligatoria.
- ✓ **VPN Cisco:** Acceso remoto cifrado seguro.
- ✓ **AES-256:** Cifrado de datos en reposo.
- ✓ **Respaldo 3-2-1:** 3 copias, 2 medios, 1 fuera de sitio.
- ✓ **EDR:** Detección y respuesta en Laptops.

Cláusula de Cumplimiento

El incumplimiento de estas políticas puede resultar en la revocación de accesos y sanciones disciplinarias. La seguridad es responsabilidad de cada colaborador.

CONFIDENTIAL

BUENAS PRÁCTICAS

✓ RECOMENDADO

- ✓ Bloquear equipo al ausentarse.
- ✓ Usar contraseñas robustas.
- ✓ Reportar correos sospechosos.
- ✓ Mantener software actualizado.

✗ EVITAR

- ✗ Compartir contraseñas.
- ✗ Conectar USBs personales.
- ✗ Descargar archivos no autorizados.
- ✗ Dejar información sensible a la vista.

Identificando el Phishing

No te dejes engañar. Los atacantes suelen usar:

 **Urgencia:** "Tu cuenta será bloqueada".

 **Remitente:** Direcciones que no coinciden con Bosch.

 **Links:** Enlaces que llevan a sitios externos extraños.

Acción: Ante la duda, no hagas clic. Reporta inmediatamente al área de TI mediante el canal oficial.



CONFIDENTIAL

RESPONSABILIDAD DE TODOS



Cultura de Seguridad

La seguridad de la información no depende únicamente del área de TI, sino de cada colaborador en Robert Bosch.

"Nosotros somos la primera línea de defensa de la compañía."

BENEFICIOS DEL SGSI

- ✓ **Operativos:** Garantiza la continuidad del negocio EDI.
- ✓ **Estratégicos:** Fortalece la confianza con clientes globales.
- ✓ **Técnicos:** Reduce vulnerabilidades en OutSystems.
- ✓ **Normativos:** Cumplimiento total con ISO/IEC 27001.



Conclusión

La implementación del SGSI protege los activos críticos del departamento **EDI/4**, fortaleciendo nuestra cultura organizacional y asegurando un futuro resiliente.

Seguridad de la información: Responsabilidad de todos.

CONFIDENTIAL

¿Preguntas?

Gracias por su atención

Robert Bosch México | Sistemas Automotrices
San Luis Potosí, México | Mayo 2026

CONFIDENTIAL



8. Operación

Dentro de las 20 políticas establecidas, la política sobre el uso de los teléfonos móviles del personal full-time establece:

“Los dispositivos móviles que procesen o accedan a datos del departamento EDI deben ser gestionados de manera segura.”

Esto debido a que si se llega a hacer un mal uso se puede lograr una escala de privilegios mediante el dispositivo móvil hacia la red del sistema u otros dispositivos de la empresa (activos).

La línea base de la política menciona la operación para implementar la política, la cual establece:

“La política del MDM forzará un código de desbloqueo (PIN) mínimo de 6 dígitos numéricos o autenticación biométrica de forma predeterminada.”

Para implementar esta política es necesario contar con un teléfono de la empresa, ser personal full-time de Bosch e implementar la siguiente configuración:

1. Ingresamos a la aplicación de configuración en el dispositivo
2. Seleccionamos la opción FaceID & Passcode
 - Autenticación biométrica

Se implementa una autenticación biométrica para establecer un control de acceso seguro al dispositivo móvil, garantizando que únicamente el titular autorizado pueda desbloquearlo y acceder a la información corporativa almacenada o procesada en el mismo. Esta medida se alinea con la política de gestión de dispositivos móviles (MDM) del departamento EDI4 y contribuye a mitigar el riesgo de accesos no autorizados en caso de pérdida o robo del equipo.

8.1 Planificación y control operacional

El departamento EDI/4 de Robert Bosch Sistemas Automotrices, S.A. de C.V. planifica, implementa, controla, supervisa y revisa los procesos necesarios para cumplir con los requisitos de seguridad de la información establecidos en el SGSI. Para ello, se han definido los siguientes elementos de control operacional:

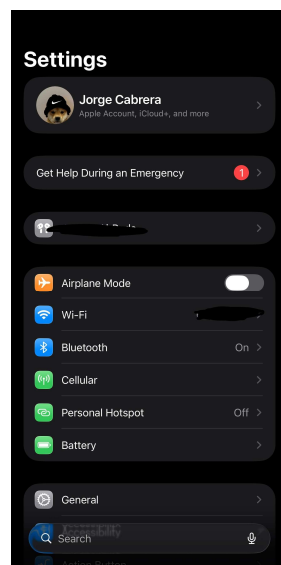
- Criterios para los procesos: Se han documentado los procedimientos operativos relacionados con el acceso a sistemas, gestión de incidentes,



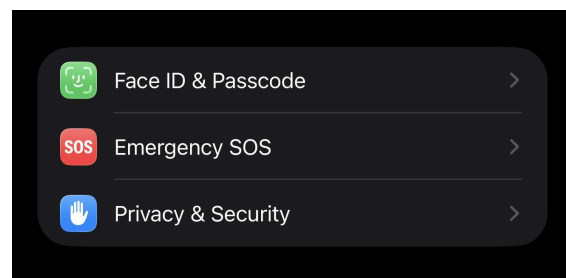
respaldo de información y control de cambios, garantizando que cada proceso cuente con criterios de aceptación y controles definidos.

- **Control de cambios planificados:** Cualquier modificación en la infraestructura tecnológica, plataforma OutSystems o procesos del departamento es gestionada mediante un proceso formal de control de cambios, evaluando el impacto en la seguridad de la información antes de su implementación.
- **Procesos externalizados:** Se identifican y controlan los procesos contratados externamente que afectan la seguridad de la información, como servicios en la nube (AWS S3, SaaS), soporte remoto de terceros y proveedores de VAN para transacciones EDI. Cada proveedor debe cumplir con los requisitos de seguridad establecidos por Bosch.
- **Documentación de la información:** Se mantiene información documentada en la medida necesaria para tener confianza en que los procesos se han llevado a cabo según lo planificado. Esto incluye registros de acceso, logs de sistemas SIEM, actas de reuniones y reportes de incidentes.

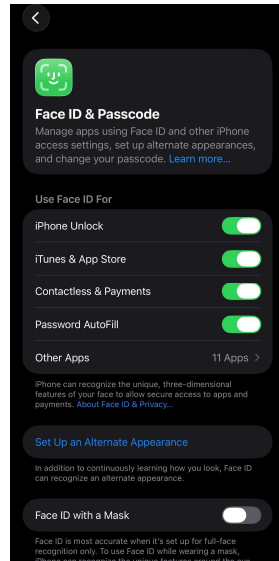
A continuación, se presenta la evidencia de la implementación de la configuración de autenticación biométrica en los dispositivos móviles del personal full-time del departamento EDI/4:



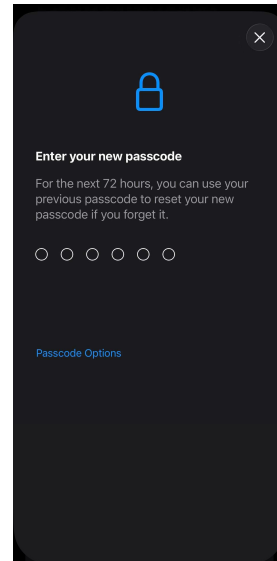
Paso 1: ingresar a la aplicación de configuración del dispositivo



Paso 2: Seleccionar la opción de FaceID & Passcode



Paso 3: Activar el FaceID e hacer la prueba para la configuración del biométrico



Paso 4: Seleccionar la opción de agregar un passcode e ingresar el código de 6 dígitos que sea de tu preferencia.



9.Evaluación del Rendimiento

Checklist de Auditoría Interna del SGSI

Este documento establece el resultado de la auditoría interna para el Sistema de Gestión de Seguridad de la Información (SGSI) del departamento EDI/4 de Bosch. Se han evaluado 20 políticas y controles clave basados en ISO/IEC 27001 y las guías del INCIBE.

Instrucciones para el Auditor: Para cada control, evalúe el nivel de cumplimiento indicando "Cumple", "No Cumple" o "Parcial" . Es imperativo detallar en la columna de evidencias los documentos revisados, configuraciones comprobadas o entrevistas realizadas que sustenten la evaluación.

No.	Política / Control de Seguridad	Estado	Evidencias / Observaciones (Hallazgos)
1	Política General de Seguridad: Aprobada y comunicada a todo el personal.	Cumple	Documento "Política SGSI V2.0" firmado por el Director de Planta. Comunicado vía boletín interno el 15/01/2026.
2	Revisión de Políticas: Se evalúan y actualizan al menos anualmente.	No Cumple	La política de teletrabajo no se ha actualizado desde hace 18 meses. Requiere revisión por RRHH y TI.



3	Roles y Responsabilidades: Definidos y asignados formalmente.	Cumple	Matriz RACI de ciberseguridad publicada en la intranet corporativa (Confluence).
4	Seguridad en Proyectos (Security by Design): Integrada desde el inicio.	Parcial	2 de 5 proyectos nuevos de EDI/4 omitieron la fase de evaluación de riesgos inicial. Se levantó no conformidad menor.
5	Inventario de Activos: Actualizado y detallado (hardware y software).	Cumple	Revisión de la plataforma GLPI; el escaneo de red coincide en un 98% con el registro documental.
6	Clasificación de la Información: Uso de etiquetas (Pública, Interna, Confidencial).	No Cumple	Se encontraron reportes financieros en servidores compartidos sin la etiqueta de "Confidencial".
7	Borrado Seguro y Destrucción: Eliminación certificada de datos	Cumple	Se revisaron actas de destrucción magnética emitidas por proveedor



	en equipos obsoletos.		externo (Folio #8472) de 15 laptops.
8	Principio de Mínimo Privilegio: Permisos limitados estrictamente a las funciones del rol.	Cumple	Auditoría de Active Directory: No hay usuarios operativos en el grupo de Domain Admins.
9	MFA y VPN: Autenticación multifactor para servicios en la nube y accesos remotos.	Cumple	Logs de Microsoft Entra ID verificados; el 100% de accesos VPN Cisco exigen validación de token.
10	Gestión de Altas y Bajas: Retirada inmediata de accesos al cesar labores.	No Cumple	Se identificaron 2 cuentas de ex-empleados que permanecieron activas por más de 72 horas después de su salida.
11	Monitoreo de Accesos: Registro de intentos fallidos de autenticación.	Cumple	Alertas activas en el SIEM corporativo. Se verificó el bloqueo automático tras 5 intentos fallidos de contraseña.



12	Control de Acceso Físico: Protección en CPD y áreas restringidas.	Cumple	Se constató funcionamiento de lectores biométricos y cámaras en la entrada del site principal.
13	Regla de Backup 3-2-1: Copias de seguridad periódicas y descentralizadas.	Cumple	Logs de Veeam Backup confirmados. Se almacenan copias inmutables en AWS S3.
14	Pruebas de Restauración (Disaster Recovery): Verificación de integridad de backups.	No Cumple	No existe evidencia documentada de un simulacro de restauración de la base de datos principal en el último año.
15	Protección Endpoint (EDR/Antimalware): Software actualizado en todas las estaciones.	Cumple	Consola centralizada muestra el 99.5% de los equipos con el agente EDR de CrowdStrike en estado óptimo.
16	Cifrado AES-256: Aplicado en laptops y	Cumple	Validación mediante GPO (Políticas de Grupo). BitLocker



	transferencia de datos sensibles.		está activo y no puede ser deshabilitado por el usuario.
17	Gestión de Vulnerabilidades y Parches: Actualizaciones críticas instaladas a tiempo.	Cumple	Reporte de escaneo Nessus sin vulnerabilidades de severidad "Crítica". Parches desplegados vía WSUS en la semana 2.
18	Plan de Respuesta a Incidentes: Documentado y con equipo de respuesta designado.	Cumple	CSIRT interno conformado. El procedimiento de escalamiento fue actualizado en febrero de 2026.
19	Firma de Acuerdos de Confidencialidad (NDA): Obligatorio previo al acceso a sistemas.	Cumple	Muestreo aleatorio de 20 expedientes en RRHH, todos contienen el NDA debidamente firmado.
20	Campañas de Concientización y Phishing: Formación periódica al personal.	Parcial	Se realizó la capacitación, pero la campaña de simulacro de phishing tiene más de un año de atraso.



Resumen de la Auditoría

- **Total de controles evaluados:** 20
- **Controles en cumplimiento:** 14
- **Incumplimientos identificados:** 4
- **Cumplimientos parciales:** 2

Firma y Validación

Fecha de la Auditoría: 13 de Mayo de 2026

Auditor Líder (Nombre y Firma): Ailton Israel Dominguez Hernandez

Responsable del SGSI (Nombre y Firma): Diego Lopez Castro

10. Mejora

10.1 Descripción del Incidente: ¿Qué sucedió?

El día de ayer, un colaborador perteneciente al equipo EDI/4, fue víctima del robo de su equipo de cómputo portátil corporativo mientras laboraba de manera remota en una cafetería pública.

El colaborador se encontraba trabajando con el equipo encendido y la sesión iniciada. Al recibir una llamada telefónica personal que requería privacidad, se levantó de su mesa y salió de las oficinas; según cuenta el susodicho, dejando la laptop desbloqueada. Al regresar a su lugar minutos después, el equipo ya no se encontraba en la mesa. Debido a que el equipo fue sustraído mientras estaba en uso, existió una ventana de riesgo crítica en la que un tercero no autorizado pudo haber accedido a información corporativa antes de que la pantalla se bloqueara automáticamente.



10.2 Análisis de Causa Raíz: ¿Por qué se materializó la amenaza?

La materialización de este incidente no se debió a una falla en la infraestructura tecnológica, sino a una combinación de negligencia humana y una ventana de vulnerabilidad en la configuración de la línea base. El análisis detalla lo siguiente:

- **Falla en la Seguridad Física:** El usuario violó los principios básicos de custodia de activos al abandonar un equipo corporativo en un espacio público de alto tránsito. La capacitación actual se enfoca exclusivamente en riesgos digitales (*phishing*), dejando un vacío en la concientización sobre seguridad física e ingeniería social presencial.
- **Brecha en la Línea Base de Configuración:** La línea base establece un bloqueo de sesión tras 5 minutos de inactividad. Dado que el robo ocurrió escasos minutos después de que el usuario se levantara, el ladrón sustrajo un equipo con la sesión de Windows activa. Esto neutralizó temporalmente la protección de primer nivel que ofrece el cifrado de disco (Estándar), ya que el sistema operativo estaba desbloqueado en el momento de la sustracción.
- **Efectividad del Procedimiento Reactivo:** Aunque la prevención falló, el diseño del protocolo de respuesta mitigó el impacto. El usuario actuó dentro del margen de la primera hora, permitiendo contener la brecha antes de que el equipo pudiera ser desconectado de la red para extraer datos de forma prolongada.

10.3 Línea Temporal del Incidente (Cronología)

A continuación, se presenta la secuencia exacta de los hechos, evaluando los tiempos de respuesta frente al Procedimiento establecido:

- 09:15 a.m. - El usuario del equipo EDI llega a la cafetería e inicia su jornada laboral de forma remota. El EDR reporta conexión estable y el disco se encuentra correctamente cifrado.
- 10:42 a.m. - El usuario recibe una llamada telefónica y abandona la mesa, dejando la laptop abierta y con la sesión activa. Comienza a correr el temporizador de 5 minutos de la línea base para el bloqueo por inactividad.
- 10:44 a.m. - (*Estimado según cámaras del local*) Un individuo ajeno sustrae el equipo de la mesa y abandona el lugar. La sesión del usuario aún se encuentra activa (minuto 2 de inactividad).
- 10:48 a.m. - El usuario regresa a la mesa, se percata de la ausencia del equipo y comienza a buscarlo en las instalaciones.



- 11:15 a.m. - Tras confirmar el robo, el usuario se comunica de inmediato con la mesa de ayuda de TI. (Cumplimiento del Procedimiento Paso 1: Notificación dentro de la primera hora).
- 11:22 a.m. - El equipo de Seguridad de TI localiza el dispositivo en la consola del MDM/EDR (el equipo seguía conectado a una red móvil/Wi-Fi) y ejecuta el comando de bloqueo de pantalla forzado y borrado remoto de nivel militar. (Cumplimiento del Procedimiento Paso 2).
- 11:25 a.m. - La consola de TI confirma que el comando de borrado remoto (Wipe) ha sido recibido y ejecutado con éxito. A partir de este momento, entra en rigor la protección del cifrado de disco (Estándar), imposibilitando la recuperación de la información por métodos forenses de terceros.
- 01:30 p.m. - El usuario acude al Ministerio Público y levanta el acta por robo, enviando posteriormente la copia digitalizada al departamento de Recursos Humanos y TI. (Cumplimiento del Procedimiento Paso 3).

10.4 Conclusiones y Plan de Acción

El incidente demuestra que los controles técnicos reactivos (EDR, cifrado y borrado remoto) funcionaron exactamente como fueron diseñados, evitando una fuga de datos masiva. Sin embargo, la brecha inicial confirma la necesidad de ajustar las políticas preventivas.

Acciones de Mejora Propuestas:

1. Actualización de la Línea Base: Reducir el tiempo de inactividad para el bloqueo de pantalla de 5 minutos a 3 minutos en todos los equipos del personal EDI, mitigando la ventana de exposición física.
2. Ampliación de la Directriz (Capacitación): Modificar la formación anual. Además de la identificación de *phishing*, se debe incluir un módulo obligatorio sobre Seguridad Física de Activos Tecnológicos y la adopción del hábito de bloqueo manual inmediato (atajo *Windows + L* o *Command + Control + Q*) al alejarse del equipo.

SGSI - ISO 27001

Mejora Continua

Gestión de Incidentes y Plan de Acción Preventivo

Departamento EDI/4 - Robert Bosch Sistemas Automotrices

Responsables

Ávalos Rangel Hazel Mario – 181801
Cabrera Meza Jorge Alejandro - 183095
González Delgado Ángel Josué - 182837
López Castro Diego – 182032
López Monsiváis Jorge Emmanuel – 179842

CONFIDENTIAL

Análisis de Incidente Crítico

Evaluación forense y lecciones aprendidas tras el compromiso físico
de un activo corporativo.

CONFIDENTIAL



DESCRIPCIÓN DEL INCIDENTE

¿Qué sucedió?

Un colaborador del equipo EDI/4 sufrió el robo de su laptop corporativa mientras trabajaba de forma remota en una cafetería pública.

⚠ Negligencia: El equipo se dejó desbloqueado y sin supervisión.

🕒 Exposición: Sesión activa durante el robo, facilitando acceso potencial a datos.

🕒 Riesgo: Ventana crítica antes del bloqueo automático.



CONFIDENTIAL

ANÁLISIS DE CAUSA RAÍZ

Factor Humano

Incumplimiento de las políticas de custodia física. La formación se centraba en riesgos digitales, omitiendo la seguridad física presencial.

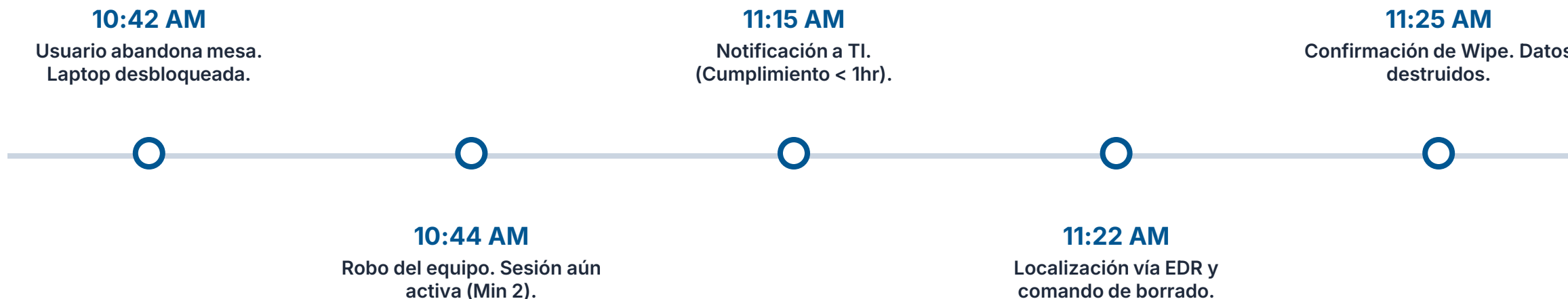
Brecha Técnica

La configuración de bloqueo (5 min) era demasiado amplia para entornos públicos, permitiendo que el ladrón tuviera acceso inmediato al SO.

Respuesta Eficaz

El protocolo reactivo (EDR/Borrado Remoto) funcionó, mitigando el impacto final a pesar del error inicial del usuario.

CRONOLOGÍA DEL INCIDENTE



CONFIDENTIAL

EFFECTIVIDAD DEL PROTOCOLO

33m

Tiempo de Reporte

10m

Respuesta de TI

100%

Integridad Salvada

"La contención rápida evitó que el incidente escalara a una brecha de datos masiva."

CONFIDENTIAL



Plan de Acción y Mejora

Transformando vulnerabilidades en fortalezas
institucionales.

ESTRATEGIA PREVENTIVA



Baseline 3.0

Reducción del bloqueo de pantalla automático de 5 a 3 minutos para todo el personal EDI.



Formación Física

Nuevo módulo obligatorio: "Custodia de Activos en Espacios Públicos" (Ingeniería Social Presencial).



Cultura Win+L

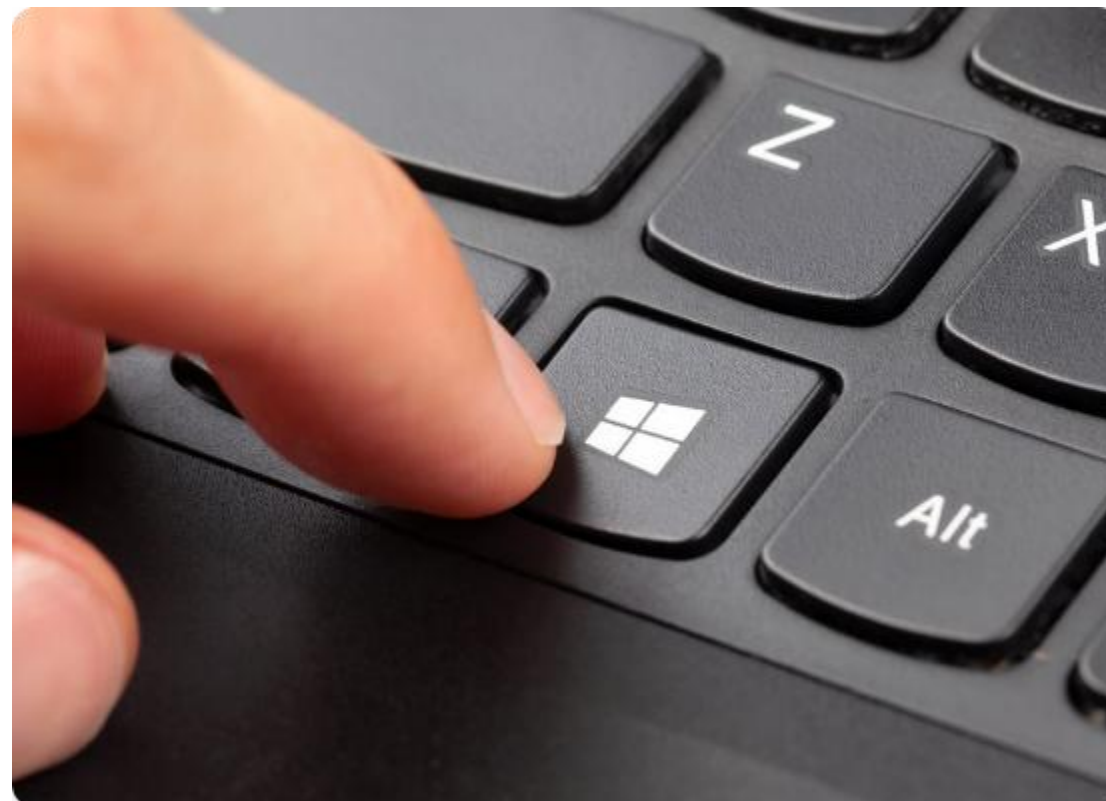
Campaña de concientización para el bloqueo manual instantáneo al levantarse.

HÁBITO DE SEGURIDAD

Win + L: El atajo que salva datos

Un segundo de acción previene meses de investigación. Nuestra nueva directriz enfatiza:

- Bloqueo manual mandatorio al alejarse a más de 1 metro del equipo.
- Uso de candados Kensington en lugares fijos.
- Notificación inmediata ante comportamiento sospechoso en el entorno.



CONFIDENTIAL

TUS 5 SEGUNDOS VALEN ORO

En espacios públicos, la seguridad de tu equipo es TU responsabilidad.



1. BLOQUEA

Win + L antes de levantarte.



2. VIGILA

Nunca dejes tu equipo solo.



3. REPORTA

Llama a TI en < 60 min si algo pasa.

DEPARTAMENTO EDI/4 - SEGURIDAD SIEMPRE

CONCLUSIÓN

"Los controles técnicos nos salvaron esta vez, pero la prevención humana es lo que garantiza la resiliencia a largo plazo."

- ✓ EDR y Cifrado confirmados como efectivos.
- ✓ Protocolo de reporte rápido validado.
- 🔄 El SGSI se ajusta para cerrar la brecha física.

Dudas o Preguntas

La mejora continua es un esfuerzo de todos.

www.bosch.com.mx | EDI/4 Robert Bosch Sistemas Automotrices

CONFIDENTIAL



LECCIÓN APRENDIDA

UN SEGUNDO ES SUFICIENTE

EL INCIDENTE

Un equipo de cómputo portátil perteneciente a EDI/4 fue sustraído en una cafetería pública. El delincuente solo necesitó una ausencia de 2 minutos del colaborador.

LA CAUSA RAÍZ

El estándar de cifrado robusto AES-256 queda completamente neutralizado si el equipo es extraído mientras la sesión de Windows permanece activa y desbloqueada.

¡NO CONFÍES EN EL BLOQUEO AUTOMÁTICO!

Robert Bosch

PROCEDIMIENTO DE CUSTODIA DE ACTIVOS CRÍTICOS

HÁBITO DE SUPERVIVENCIA DIGITAL MANDATORIO

Win

+

L

Bloqueo manual instantáneo antes de alejarte a más de un metro de tu estación de trabajo.

1. BLOQUEA

Presiona de forma mecánica el comando Win+L al levantarte. Asegúrate de ver la pantalla de bloqueo activa antes de retirar la mirada de tu laptop corporativa.

2. VIGILA

En entornos de trabajo remoto (cafeterías, hoteles, aeropuertos), tú eres el único custodio de la propiedad intelectual de Bosch. Nunca dejes activos desatendidos.

3. REPORTA

Ante cualquier pérdida o incidente, notifica de inmediato a la mesa de ayuda de TI dentro de la primera hora. La rapidez es crítica para activar el borrado remoto militar.



MESA DE AYUDA DE TI: EXT. 1900

SEGURIDAD DE LA INFORMACIÓN EDI/4
ISO/IEC 27001 • San Luis Potosí, México • Mayo 2026



Referencias bibliográficas

RocketReach. (s.f.). Bosch México Marketing Department | Bosch México Marketing Team. Recuperado el 22 de abril de 2026, de https://rocketreach.co/bosch-mexico-marketing-department_b5e1056bf42e6a1a

The Official Board. (2026, 17 de marzo). Bosch Org Chart + Executive Team. Recuperado el 22 de abril de 2026, de <https://www.theofficialboard.com/org-chart/bosch-1>

The Official Board. (s.f.). Organigrama de Bosch North America. Recuperado el 22 de abril de 2026, de <https://www.theofficialboard.es/organigrama/bosch-north-america>